SoK: When Do LLM Side-Channel Defenses Protect Agent Workflows? A Result-Record Repository, Comparability Audit and Boundary Analysis

October 21, 2026

***Abstract*—**When does a side-channel defense evaluated on an isolated LLM component protect an autonomous agent workflow? Unlike single-turn inference, an agent workflow couples a *multi-hop observation path* (where downstream renderers or backward passes can re-emit protected signals) with a *stateful execution path* (where cover actions interact with live tools and GUIs). Rather than claiming new security axioms beyond end-to-end placement, state isolation or adaptive evaluation, we contribute a source-bound *result-record repository* (82 study families: 58 core, 24 adjacent; 39 intervention result records across 78 utility/cost fields), a nine-item comparability audit and controlled boundary tests across both paths. Each record binds its threat polarity (Type I confidentiality, Type II attribution, Type III bot-detection evasion, Type IV diagnostics), final receiving projection, cover execution semantics, and matched adaptation (D_2) and cost objects. On a 24-scenario retrospective deployment-transfer benchmark, two independent expert coders applying this three-check record procedure reach 93.8% mean accuracy (95.8% and 91.7%, catching 100% and 91.7% of documented deployment failures; inter-coder agreement 87.5%, $\kappa = 0.795$), versus 29.2% (0% failure recall) for a deterministic headline-metric reuse baseline. Independent dual-coding across 100 screening records ($\kappa = 0.886$), 144 split-audit cells ($\kappa = 0.876$) and 150 pairwise judgments ($\kappa = 0.916$) establishes coding reliability. Real loopback TLS 1.2 replays across 48 saved responses (four natural task-granularity regimes, $d \in [0.25, 10.4]$) and joint privacy–utility evaluations across 115 τ-bench retail reference tasks (97 tasks with an eligible pending order, $\times 3$ seeds $\times 2$ insertion positions) establish three synthesis insights: (1) required terminal framing overhead scales with natural target length separability (512B bucketing eliminates medium/short exposition leakage at $0.87\times$–$0.91\times$ baseline wire bytes, whereas directive verbosity requires 1,024B bucketing at $1.94\times$ or constant capping at $23.37\times$); (2) in stateful agent tools, *payload idempotence does not imply state-machine idempotence*—mapping an order item to its own identical `item_id` ($\Delta\text{price} = 0$) still triggers a one-way `"pending (item modified)"` status transition that breaks 59.45% of eligible pre-insertion tasks, whereas state-idempotent address writes and decoy-account isolation preserve 100% user-account state; and (3) retraining an adaptive observer (D_2) rebounds attacker accuracy by $+20.8$ to $+21.1$ percentage points on bucketed/stochastic TLS streams and $+22.5$ to $+49.0$ points on retail tool-dispatch traces relative to a clean-trained (D_0) observer.

I Introduction

Encryption conceals message content, yet LLM serving engines and autonomous agents expose rich side-channel projections: packet-size streams, KV-cache hit/miss timing, hardware memory-access patterns, visited web domains and tool-invocation sequences [1, 2, 3, 4, 5, 6]. As the literature has grown rapidly, system designers face an acute *composition fallacy*: defenses evaluated on an isolated LLM component or offline trace are routinely assumed to protect an end-to-end agent workflow.

Why does a component defense result fail to transfer unchanged to an agent workflow? Synthesizing 82 study families (58 core, 24 adjacent), we show that embedding an LLM inside an agent workflow introduces three structural boundaries that isolated benchmarks do not test together:

1. **The Observation Projection Boundary (Trace Path):** An agent workflow chains serving backends, orchestration layers, content-aware rendering frontends and split-model return paths. Upstream traffic shaping preserves its information bound ($I(S;Y) \le I(S;Z)$, Proposition 1) *only* if downstream stages are target-oblivious postprocessors. When a content-aware frontend decrypts, strips padding and re-chunks decoded tokens [7], or when a backward pass returns gradients with unprotected nonzero row support [8], it creates a secondary emitter that restores target distinguishability.

2. **The Action State-Machine Boundary (Execution Path):** In classical network privacy or read-only retrieval (such as the Web and Research Agents study, WRA [6]), "cover traffic" consists of read-only dummy queries whose responses are discarded locally. In an autonomous agent workflow, admitting cover actions to live tool or GUI dispatch interacts with *stateful external environments* (such as the Agent Humanization Benchmark, AHB [9], or transactional tool APIs). Crucially, we uncover **the Idempotence Illusion**: in stateful tool APIs, *argument-level payload idempotence does not imply state-machine idempotence*. Calling a tool to replace an item with its own identical `item_id` at zero price difference still triggers one-way workflow status transitions (`"pending (item modified)"`) and append-only ledger entries that silently break subsequent user actions.

3. **The Evaluation Coupling Boundary (D_2–Utility–Cost Trilemma):** Across the 20 core families that evaluate mitigations (39 result records across 78 utility/cost fields), studies routinely measure one vertex of the security–utility–cost triangle against a static clean-trained (D_0) observer and extrapolate to whole-workflow protection—omitting either adaptive retraining on the defended distri-

bution (D_2), objective task-state preservation, or workload-level cache-reuse loss [3, 10, 11].

Positioning: a result-record repository and comparability audit We do not claim to invent the end-to-end principle, state isolation or adaptive evaluation; original study authors frequently note local instances of these phenomena. Rather, our contribution is systematizing the fragmented LLM and agent side-channel literature into a **source-bound result-record repository, a nine-item comparability audit, and a three-check operational procedure** that lets practitioners and reviewers determine exactly when a published measurement transfers to a target workflow. Without structured record binding, relying on paper-level headline metrics fails systematically: on a 24-scenario retrospective deployment-transfer benchmark drawn from our corpus, an objective baseline rule that accepts any defense reporting favorable local attack suppression or $< 10\%$ component overhead achieves only 29.2% accuracy (7/24) and catches **0% (0/12)** of documented deployment failures. By contrast, two independent expert coders applying our three-check record procedure reach **95.8% (23/24)** and **91.7% (22/24)** accuracy (mean **93.8%**, +64.6 percentage points over baseline; 87.5% inter-coder agreement, $\kappa = 0.795$).

Summary of SoK contributions

- **Unified 82-family repository and threat-polarity taxonomy (Sections II–IV):** We index 82 study families (58 core, 24 adjacent) and 39 intervention result records (78 utility/cost fields across all 58 core families), explicitly separating (Type I) confidentiality protection, (Type II) provenance/identity attribution, (Type III) bot-detection evasion, and (Type IV) authorized operator diagnostics. Independent human/expert dual-coding across 100 screening records ($\kappa = 0.886$), 144 split-audit cells ($\kappa = 0.876$) and 150 pairwise comparability judgments ($\kappa = 0.916$) establishes high interpretive reliability.
- **Nine-item split reporting audit and retrospective transfer benchmark (Sections III and VI):** We split adaptation into protected-condition fitting (D_1, Check 4a) versus matched clean-versus-adapted testing (D_2, Check 4b), and decompose joint evaluation into defended inference effect (Check 6a), task/component utility (Check 6b) and mechanism/protocol cost (Check 6c) across all 20 evaluated-mitigation families, showing that while 85% bind inference effects and 55% bind component cost, only 15% bind utility, 10% bind D_2 adaptation, and only one family (`CachePrune` [12]) binds all three on the same operating point.
- **Real TLS 1.2 socket replays and joint privacy–utility retail cover experiments across all three checks (Section VIII):** (i) Using real loopback TLS 1.2 sockets across 48 unmodified `gpt-6-luna` outputs spanning four natural task-granularity regimes ($d \in [0.25, 10.4]$), we map how bucketed terminal framing trades wire overhead ($0.87\times$–$1.94\times$) against natural target length separability and quantify the $D_0 \to D_2$ adaptation rebound (+20.8 to +21.1pp); and (ii) across 115 τ-bench retail reference tasks (97 tasks with an eligible pending order, $\times 3$ seeds $\times 2$ insertion positions), we jointly evaluate task utility and D_0/D_2 observer inference across nine baseline and realistic cover policies (including state-idempotent address writes, payload-idempotent item self-writes, an oracle-free instruction-aware cover selector and decoy-account isolation).

TABLE I
Observable-based eligibility. A hidden target alone does not make a semantic attack a side channel.

Observed input	Decision and required distinction
Length, timing, cache response	Core when measured execution dependence supports hidden-target inference.
Own-site actions	Core attribution with site permission; no automatic access to other sites or private tool logs.
Reply states the secret	Direct disclosure; adjacent, not auxiliary-channel evidence.
Reply style/content identifies a user	Adjacent unless a separately evaluated auxiliary mechanism is established. WildAuth stays a mixed-view comparator.
Output-filter membership oracle	Can be core: the filter's execution, not ordinary semantic output inference, mediates the signal.
Privileged loop/fault logs	Separate diagnostic component when C1–C5 hold; does not increase confidentiality evidence.

Figure 1 separates the trace and action paths; Figure 2 summarizes the three-check record procedure.

II Scope and Systematization Method

II-A Research questions, eligibility and threat polarity

We organize the systematization around four questions: which hidden targets, threat polarities and auxiliary observables appear across LLM and agent systems (RQ1); how signal generation origin relates to receiver observation permissions (RQ2); which holdouts establish portability across tasks, configurations and hardware (RQ3); and when a component intervention protects an end-to-end workflow at a bounded utility and cost (RQ4).

Core inclusion requires five conjunctive criteria: (C1) LLM or agent execution, (C2) a hidden target property, (C3) an execution-dependent auxiliary observable rather than ordinary output semantics alone, (C4) specified observer permissions, and (C5) an empirical inference evaluation. Mixed-feature papers qualify only if they isolate an auxiliary-only C3 component; thus coding fingerprints, WildAuth, ZeroPrint, endpoint-content fingerprints and StepFinder remain adjacent boundary comparators [13, 14, 15, 16, 17]. Table I states the observable eligibility rules.

A central methodological contribution of our repository is separating four mutually incompatible *threat polarities* that prior surveys conflate under generic "attack/defense" labels:

1. **Type I (Confidentiality and privacy protection):** An unauthorized observer attempts to infer private user prompts, personal traits, visited domains or proprietary model states; the defense protects user or tenant confidentiality (e.g., NetEcho, WRA, Early Bird, KVGov, CachePrune, OTRO [7, 6, 3, 10, 12, 18]).

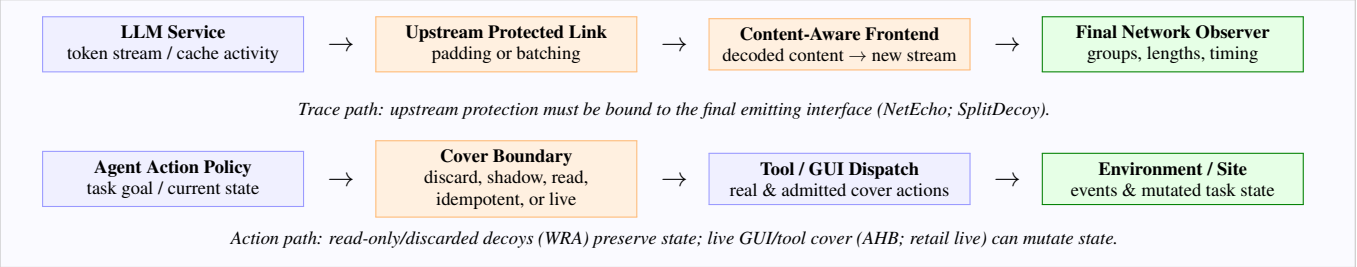


FIGURE 1
Two paths tracked by each result record in an agent workflow. The top path distinguishes an upstream protected link from a downstream content-aware emitter or return path; the bottom distinguishes discarded, shadow-isolated, read-only or state-idempotent cover from state-mutating actions admitted to live tool/GUI execution.

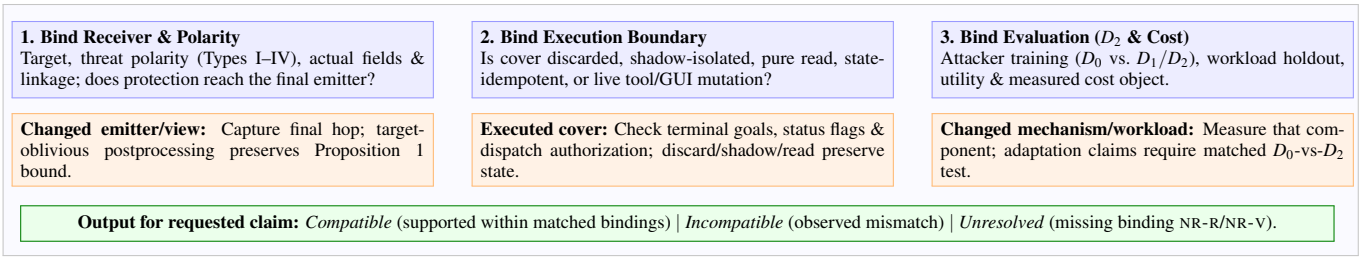


FIGURE 2
Three-check operational procedure for auditing whether a reported defense record transfers to a target agent deployment.

2. **Type II (Provenance and identity attribution):** An observer infers which model, agent harness or user identity generated a trace from timing, packet or DOM event structure (e.g., UI Traces, FP-Agent, AgentPrint, Lidar [5, 19, 4, 20]).

3. **Type III (Human–agent / bot-detection evasion):** The receiving platform operates a defensive classifier to detect automated bots, while the agent applies "action humanization" (e.g., AHB [9]) to evade detection—inverting the defender/attacker polarity relative to Type I privacy protection.

4. **Type IV (Authorized operator diagnostics):** Privileged loop detection, serving root-cause localization or internal residual-stream monitoring (ClawGuard, cycle detection, LumiMAS, LLM RCA, MIRAGE [21, 22, 23, 24, 25]), which use C1–C5 auxiliary signals for legitimate system telemetry rather than privacy exploitation.

II-B Seed-anchored purposive corpus and exact reconciliation

Because LLM and agent side-channel papers are scattered across security conferences, systems venues and preprints under heterogeneous terminology ("remote keylogging," "prompt-cache leakage," "workflow fingerprinting," "agent humanization"), our corpus is constructed through *purposive seed selection, venue-targeted proceedings screening (IEEE S&P, USENIX Security, NDSS, ACM CCS, PMLR) and one-hop backward/forward citation snowballing* from 40 fixed seeds (2,237 backward reference occurrences and 24 distinct forward works screened; 38/40 forward seeds resolved), complemented by native database exports and bulk keyword searches (Appendix Appendix A and Supplement S1/S10).

To document why standalone Boolean keyword queries cannot replace seed-and-snowball discovery, we audited both our historical October 8 native IEEE/ACM exports and a completed October 21 supplementary search frame comprising four Semantic Scholar title/abstract bulk queries and two native arXiv searches (615 occurrences deduplicated to 565 unique records; Table II). Those six supplementary keyword queries returned 17/24 of a fixed 24-paper core subset of our 40 seeds (`seed_n=24`) and 25/60 of the October 8 snapshot. Because the 24 known papers are a core subset of the 40 initial seeds rather than an external holdout, 17/24 and 25/60 measure *lexical overlap between narrow Boolean queries and our seed-anchored corpus*, not calibrated database recall: the two native arXiv queries required the exact hyphenated string `"side-channel"` (missing studies titled with "prompt leakage," "keylogging," "timing attacks" or "fingerprinting"), and Semantic Scholar title/abstract matching did not search full texts of USENIX/NDSS PDFs.

Table II reconciles every record across the 60 → 82 transition. All 58 core families (20 workflow-origin, 38 inherited-runtime/application; 53 non-diagnostic and 5 Type IV diagnostic) and 24 adjacent families are integrated into the unified corpus maps and intervention dispositions (Supplement S2/S5). Across the 58 core families, 20 evaluate mitigations (16 from the October 8 snapshot contributing 33 result records, plus 4 from the October 21 expansion contributing 6 result records, totaling **39 result records and 78 utility/cost field positions**).

II-C Independent human dual-coding and reliability

To ensure that eligibility routing, split-check auditing and pairwise comparability judgments do not rely solely on a single AI-assisted workflow, a domain-expert human researcher inde-

TABLE II
Item-by-item reconciliation of the 565-record October 21 search frame (before and after the 204-record exclusion audit) and the transition from the 60-family snapshot to all 82 coded families.

Route / family category	Pre-audit	Audit Δ	Final (Indexed)
Excluded: no hidden C2/C3 target	221	−4	217 (0)
Excluded: outside LLM / diff. target	175	0	175 (0)
Existing snapshot core / adjacent	23 / 1	+1/0	24 / 1 (in 60)
New source-verified core families	14	+1	15 (**+15**)
Adjacent source-reviewed contexts	28	+2	30 (**+7**)
Adjacent metadata-only contexts	28	0	28 (0)
Background / proposal metadata	58	0	58 (0)
Missing abstract / unavailable text	17	0	17 (0)
565-frame total / Net added families	**565**	**0 net**	**565 (+22)**
Coded collection: Core / Adjacent (**Total**)	Snapshot: 43 / 17 (**60**) → Full: 58 / 24 (**82**)		

The 204-record exclusion audit rerouted 4 records out of the 221 initial C2/C3 exclusions: (1) `SUP-0192` (MIRAGE [25]) moved to new core ($14+1=15$, all 15 added to the family index); (2) `SUP-0552` (InputSnatch arXiv alias) merged into existing family `inputsnatch2024` ($23+1=24$, +0 new families); and (3–4) `SUP-0191` and `SUP-0424` moved to source-reviewed adjacent contexts ($28+2=30$, of which 7 boundary-defining studies enter the adjacent index and 23 remain in the 565-record ledger). Thus $60+15$ (core) $+7$ (adjacent) $=82$.

pendently dual-coded three stratified samples against the primary coding workflow using primary source texts and locators (`experiments/revision-m1-m8/`):

1. **Screening and C1–C5 eligibility ($n = 100$ stratified records from the 565-record frame):** Independent three-class routing (*Core*, *Adjacent*, *Excluded/Background*) achieved **93.0% raw agreement (93/100)** and **Cohen's $\kappa = 0.886$** (95% bootstrap CI $[0.801, 0.963]$); binary Core inclusion achieved **95.0% agreement** and $\kappa = 0.880$ ($[0.764, 0.975]$).

2. **Nine-item split reporting audit ($n = 144$ cells across the 16 baseline evaluated-mitigation families):** Independent five-state coding (*Bound*, *Partial*, NR-R, NR-V, NA) achieved **93.1% raw agreement (134/144)** and $\kappa = 0.876$ (95% CI $[0.798, 0.943]$).

3. **Pairwise comparability audit ($n = 50$ pairs; all 13 within-family pairs plus 37 related-cohort pairs, 150 judgments across descriptive, paired-effect and transfer rules):** Independent coding achieved **94.0% raw agreement (141/150)** and $\kappa = 0.916$ (95% CI $[0.856, 0.963]$).

SoK Takeaway 1 (Methodological Foundation). Side-channel studies across LLM serving and autonomous agents cannot be synthesized by keyword census or paper-level headline scores alone: narrow Boolean queries miss 58% of seed-and-snowball families due to terminology fragmentation, and conflating Type I privacy defenses with Type III bot-evasion click injectors or Type IV operator diagnostics distorts both security polarity and deployment risk.

TABLE III
A single result record. Only fields relevant to the requested comparison must align; unavailable required fields remain unresolved.

Record field	Required meaning
Source	Family/result ID, version, source locator, reading scope and hash.
Target	Hidden property, inference goal and protection relation: confidentiality, attribution, human/agent distinction or authorized diagnosis.
Receiver	Actual permission and released representation, including session/document linkage and any auxiliary inputs.
Intervention	Where protection ends; whether edits affect stored traces, transmission or executed actions.
Attacker	Fit/calibration condition, test population, training access and adaptation budget.
Workload	Task, system, topology/hardware and grouping/holdout.
Outcomes	Inference metric/denominator; objective or proxy utility; applicable cost object; uncertainty and field states.

III Result Records, Comparability Rules and Validity

The atomic unit of our repository is one *evaluated result record*, rather than a whole paper or a single headline score. A result record binds a source version and locator to seven structured fields: Source, Target (and threat polarity Types I–IV), Receiver projection, Intervention boundary, Attacker training/calibration (D_0 vs. D_1/D_2), Workload/holdout, and Outcomes (inference metric, task/component utility, and cost object; Table III). A study family contributes multiple records whenever it evaluates distinct execution modes (e.g., stored capture vs. live loopback in Dangol [26]), distinct mechanisms (e.g., K-prefix KV simulation vs. GPTCache semantic de-identification in Early Bird [3]), or separately scoped performance benchmarks (e.g., SafeKV [27] and OTRO [18]).

Indexing schema and comparison contracts The mnemonic SCOPE (Secret/target, Channel, Observer, Pipeline, Exploitation goal) names the target-and-channel columns of our index, paired with evaluation provenance. Generating layers span hardware (P1), serving (P2), transport (P3), application/API (P4), orchestration (P5), tools/MCP (P6), environment (P7) and multi-agent communication (P8). We apply three comparison contracts (Table IV): a comparison is *compatible* when required fields align; *incompatible* when a positive mechanism or boundary conflict is established (such as substituting token-payload ratios for wire bytes or offline timestamp edits for live action delays); and *unresolved* when a required binding is unreported (NR-R), unavailable (NR-A) or unverified (NR-V). Table V illustrates a complete record-to-judgment lineage.

Validity evaluation: catching known deployment failures Why pair our repository index with the three-check decision procedure (Figure 2)? First, in a retained 512-root synthetic model-assisted test comparing flat checklists (R), structured checklists (T) and raw SCOPE graph traversal (V; Supplement S7), V trailed T on a strict joint string-matching metric (32.16% vs. 45.12–45.31%) solely because V committed more exact-count formatting mismatches (695 vs. 476 count-formatting errors); on the *binary deployment decision itself*, V outperformed T by +1.11 to +1.30 percentage points. That diagnostic moti-

TABLE IV
Comparison rules. A known mismatch and a missing binding have different consequences.

Requirement	Condition and resulting license
Descriptive comparison	Align target, receiver permission, metric meaning and cost object. Different systems may be described together; token payload and wire bytes cannot be ranked as the same cost.
Paired effect	Compare the same defended test units and outcome. A known test-unit mismatch makes that subtraction incompatible; an unverified fit binding leaves the effect unresolved.
Deployment transfer	Establish a bridge for the changed receiver, intervention, workload, topology or hardware. A demonstrated violation blocks the proposed transfer; an untested bridge leaves it unresolved. Permit only the range and endpoints actually covered.

TABLE V
Filled record and its licensed judgment. Values are source-reported; no cross-mode effect is computed.

Join key / field	Entry
Family / result	`dangol2026workflow` / `DANGOL-livebinding`.
Version / locator	arXiv:2606.07150v3, §9.7, live-protocol paragraph after Table 5 [26].
Target / view	Workflow classification from live Oblivious HTTP (OHTTP)/Agent-to-Agent (A2A) traffic; not GUI-state observation.
Intervention	Live fixed-rate cover with fresh per-session identifiers, distinct from transformed stored captures.
Workload / testbed	Workflow classes with client, relay, gateway and agent co-located on one loopback host.
Outcome / cost	Accuracy 0.30; about 13× bytes and 11× latency in that condition.
Unresolved fields	Objective terminal task utility NR-R; precise paired live-refit comparison NR-V.
Licensed judgment	These costs describe this live protocol condition. They neither price dummy GUI actions nor prove task preservation. A matched objective endpoint is needed for the latter.

vates using SCOPE strictly as an indexing schema while executing deployment audits via the three-check procedure.

Second, to test whether the three-check procedure catches real deployment pitfalls that headline-metric reading misses, we evaluated a 24-scenario retrospective benchmark (`m1_validity_benchmark.csv`; Table VI) comprising 12 documented deployment failures/mismatches (*Incompatible*: e.g., NetEcho downstream re-emission, SplitDecoy backward gradient-support leakage, UI Traces surviving action sequences, AHB live Fake GUI touches in Trip Planning, WRA read-only decoys vs. state-mutating tool cover, Dangol capture vs. live loopback subtraction, Early Bird semantic vs. KV-prefix cost substitution, KVGov HMAC microcost vs. cache-reuse loss, SpliceDefense CTBF vs. QCP cost, OTRO unpadded TTFT vs. epoch padding, WRA Table 11 visibility utility vs. Tables 8–9 decoys, and UI Traces D_2 adaptation recovery), 5 missing-bridge transfers (*Unresolved*), and 7 valid source-local reuses (*Compatible*). An objective deterministic baseline that accepts any defense reporting a favorable local attack reduction or $< 10\%$ overhead predicts *Compatible* across all 24 scenarios, achieving **29.2% (7/24)** accuracy and **0.0% (0/12)** recall on the 12 deployment failures. Two independent expert coders applying the three-check record procedure achieve **95.8% (23/24)** and **91.7% (22/24)** accuracy (mean **93.8%**, +64.6pp gain; failure recall **100.0%** and **91.7%**), with **87.5% (21/24)** raw agreement and $\kappa = 0.795$.

TABLE VI
Validity evaluation on 24 retrospective deployment-transfer scenarios drawn from the corpus (7 Compatible local reuses, 12 Incompatible documented deployment failures/mismatches, 5 Unresolved missing-bridge cases).

Decision procedure	Overall acc.	Failure recall ($n = 12$)	Inter-coder κ
Headline-metric rule baseline[a]	7/24 (29.2%)	0/12 (0.0%)	—
Expert Coder 1 (3-check records)	23/24 (95.8%)	12/12 (100.0%)	87.5% ($\kappa = 0.795$)
Expert Coder 2 (3-check records)	22/24 (91.7%)	11/12 (91.7%)	87.5% ($\kappa = 0.795$)

[a]Objective deterministic rule: predict *Compatible* whenever the source paper reports attack-accuracy reduction or $< 10\%$ component overhead (which holds for all 24 published defense scenarios). Applying the three-check record procedure improves mean decision accuracy from 29.2% to 93.8% (+64.6pp; 95% bootstrap CI for κ: $[0.538, 1.000]$).

IV CORPUS MAP ACROSS 82 STUDY FAMILIES

IV-A Origins, receiving projections and threat polarities

Across all 58 core families in our unified repository, 38 study inherited runtime, serving or hardware channels (Origin B) and 20 study agent-workflow channels arising from orchestration, tool dispatch, browser navigation and multi-agent protocols (Origin A; Supplement S2 (Table S3)). Signal generation origin is distinct from both receiver location and threat polarity.

Type I: Confidentiality and privacy channels Inherited serving and transport attacks infer confidential prompts or topics from packet lengths, inter-packet timing, KV-cache sharing and hardware contention. Weiss reconstructs token sequences from encrypted packet lengths, whereas NetEcho recovers conversation semantics after application-layer re-chunking [1, 7]. Whisper Leak classifies prompt topics from streaming traffic; Time Will Tell uses total completion duration [28, 29]. Chosen-request cache attacks probe shared KV prefixes or semantic caches via timing oracles, while CPU-cache, GPU memory-barrier, attention-sparsity and page-migration attacks exploit co-resident hardware channels [2, 3, 30, 11, 31, 32, 33, 34, 35, 36, 37]. In split learning/inference, SplitDecoy shows that even when forward activations are masked with decoys, the zero/nonzero row support of returned backward gradients exposes real token positions [8]. At the workflow layer, WRA infers private user functional intent and personal traits from visited domain sequences [6], AgentTell uses probe websites to extract behavioural secrets [38], and routing-metadata attacks infer sensitive prompt topics from model/expert routing choices [39].

Type II: Provenance, model and identity attribution Rather than extracting private user content, Type II studies identify *which model, agent harness or user* produced a trace. UI Traces attributes browser-agent identity across 14 models from own-site DOM/JS event sequences [5]; FP-Agent combines behavioural traces with static browser attributes [19]; Agent-

Print, Whose Agent Are You?, LLM-WFIN and the cloud traffic benchmark classify workflows or model families from network flows [4, 40, 41, 42]. AgentProv audits tool-use provenance, Lidar fingerprints agent harnesses from action roles and timing, and Cross-Campaign Attribution links asynchronous attack agents [43, 20, 44].

Type III (Bot-detection evasion) and Type IV (Authorized diagnostics) Type III studies evaluate human–agent distinction [45, 9]. Here the threat polarity is inverted relative to Type I privacy: in AHB [9], the platform detector is a defensive anti-automation control, while "action humanization" is an evasion mechanism applied by the agent. Finally, five core families are Type IV authorized operator diagnostics: ClawGuard, cycle detection, LumiMAS, LLM-serving root-cause analysis (120 controlled fault injections) and MIRAGE (internal residual-stream hooks) [21, 22, 23, 24, 25].

IV-B Relationship to prior systematizations

Prior surveys establish compound-system threat models and confidential-computing boundaries. Banerjee et al. categorize cross-layer compound AI threats under MITRE tactics; Forough et al. distinguish TEE isolation boundaries from side-channel resistance and note that inference protections need not cover agent memory or action coordination [46, 47]. Kotevska et al. propose a six-element privacy contract (asset, observer, channel, permitted disclosure, guarantee, evidence) with composition conditions framed as formal conjectures [48], while classical website-fingerprinting works establish bandwidth/latency bounds for transport shaping (Tamaraw, WTF-PAD, FRONT, Walkie-Talkie) [49, 50, 51, 52]. Our distinct contribution is the *populated 82-family / 39-record repository, the empirical nine-item comparability audit, and the state-machine and adaptive-observer boundary analysis across real TLS streams and stateful agent tools*.

V Three Deployment Case Studies

Applying our repository schema to the literature resolves apparent contradictions across three fundamental deployment decisions (Table VII): (1) when upstream traffic shaping survives downstream workflow hops; (2) why read-only query decoys and live GUI humanization produce opposite task outcomes; and (3) how adaptive retraining (D_2) and mechanism-specific cost boundaries govern operating-point selection.

V-A Case 1: bind the final target-bearing emitter

The downstream re-emission boundary When an upstream LLM API applies record padding or token batching, does that protection cover the user-facing connection after an application frontend? NetEcho demonstrates that a content-aware frontend that consumes decoded upstream tokens and re-serializes responses into new chunks (Trace A token counts per group; Trace B character lengths) restores topic and conversation distinguishability [7]. SplitDecoy establishes the same boundary on a backward return path: even when forward split-model activations are obfuscated with decoys, the returned backward gradient exposes nonzero row support on every tested frame across nine seeds [8, Sections 5.1–5.3].

Proposition 1 (target-oblivious postprocessing bound). Let S be the hidden target, Z the complete protected upstream representation and Y the downstream observation. If $S \to Z \to Y$ forms a Markov chain (any downstream framing or randomization is conditionally independent of S given Z), then by the data processing inequality [53, Theorem 2.8.1],

$$I(S;Y) \le I(S;Z).$$

A content-aware frontend that decrypts, strips padding and rechunks plaintext ($S \to (Z, \text{plaintext}) \to Y$), or a backward pass that computes gradients from unprotected loss masks, violates $I(S;Y \mid Z) = 0$. Section VIII demonstrates this boundary on real loopback TLS 1.2 sockets and shows how required terminal framing overhead scales with natural task length separability ($d \in [0.25, 10.4]$).

V-B Case 2: resolve the WRA versus AHB cover asymmetry

Two axes of asymmetry: threat polarity and action risk Discussions of agent privacy often group WRA's decoy requests [6] and AHB's humanized actions [9] together as "cover traffic," creating an apparent paradox: WRA reports a clean privacy improvement (one concurrent decoy reduces functional-intent reconstruction E_{func} from 0.770 to 0.610), whereas AHB reports severe task collapse (Trip Planning success falls from 0.75 Raw to 0.15 under combined `Online+Fake` humanization).

Binding their result records shows that WRA and AHB sit at opposite poles along *two structural axes*:

1. **Threat polarity inversion (Type I vs. Type III):** WRA is a Type I privacy defense protecting a user's research intent from a network/domain observer. AHB is a Type III bot-evasion mechanism designed to make an automated mobile GUI agent mimic human touch patterns so it bypasses platform anti-automation controls.

2. **Action-interface risk magnitude (discarded read-only queries vs. live GUI state mutations):** WRA's decoys are *read-only search and retrieval prompts* whose returned pages are discarded locally before synthesis; they never invoke state-mutating tools on the user's account. By contrast, AHB's `Fake` operator injects *unfiltered live GUI touch events* directly onto stateful mobile application screens, triggering unintended navigation and form submissions. Indeed, AHB's own non-Fake `History+Long` configuration (which adjusts timing/trajectory history without fake GUI touches) retains 0.7143 task success (vs. 0.75 Raw).

Dispatch-time authorization versus terminal-state scoring Separating cover execution routes also exposes a fundamental *analytical design argument* regarding agent benchmark evaluators: terminal state-snapshot scorers (such as τ-bench's native reward, which hashes the final database state against the reference state) are **path-oblivious**. If an unconfirmed live cover action happens to perform the exact state transition that the user's task later intended (or preempts a real action so the real action fails with a status error while leaving the terminal state identical to baseline), a terminal-snapshot scorer awards a perfect

score of 1.0 despite an unauthorized cover call having mutated production state. Systems admitting cover to live dispatch must therefore enforce authorization and provenance checks at dispatch time and inspect tool state-machine transitions (such as one-way status flags or append-only audit ledgers, demonstrated in Section VIII-C).

V-C Case 3: bind adaptive retraining (D_2) and cost objects

The $D_0 \to D_2$ rebound and component-cost boundaries Selecting a defense operating point requires pairing an adaptive attacker evaluation (D_2: comparing a clean-trained classifier D_0 against a defended-trained classifier D_2 on the *exact same defended test set*) with the cost of the actual deployed mechanism. In UI Traces [5], retraining on timestamp-delayed archive traces (D_2) recovers substantial model-attribution accuracy (confirmed by our supplementary archive reanalysis on 1,135 test records: $+0.1503$ nats log-loss reduction over D_0, 98.333% CI $[0.1205, 0.1815]$; Supplement S4). Section VIII (Tables XC and XI) further demonstrates this $D_0 \to D_2$ rebound on both real TLS 1.2 streams ($+20.8$pp under 1,024B bucketing; $+21.1$pp under stochastic padding) and τ-bench retail tool traces ($+22.5$pp to $+49.0$pp).

On the cost side, record binding prevents cross-mechanism price substitution: Early Bird's 6ms/4% GPTCache semantic de-identification overhead does not price K-prefix KV-cache isolation [3]; KVGov's $1.3\,\mu$s HMAC key-derivation microcost omits workload-dependent lost cache reuse [10]; and SpliceDefense's $<$ 5ms/$<$ 1% QCP padding overhead prices chunk padding rather than combined CTBF+QCP deployment [11]. Conversely, CachePrune jointly binds marked-token attack suppression, QA/summarization utility and serving throughput on selective KV sharing [12], and OTRO bounds conditional access-count leakage ($3.94 \to 0.04$ bits given byte length) alongside separately scoped unpadded TTFT (4.59%) and epoch-padding (2.8ms) costs [18].

VI Comparability Audit Across All 58 Core Families

VI-A Unified 58-core disposition and 39-record ledger

Across all 58 core families in our unified collection (43 from the October 8 snapshot plus 15 from the October 21 expansion), every family has a verified intervention disposition (Supplement S5 (Table S11)): **20 families evaluate mitigation components** (16 snapshot + 4 additions: `wu2026cacheprune`, `lee2026otro`, `chen2026sparleak`, `hadad2026shape`), two use fixed guardrails, five evaluate interventions for other objectives or split-decoy boundaries (4 snapshot + `politis2026splitdecoy`), 22 report no mitigation evaluation within the inspected scope (13 snapshot + 9 additions), five are Type IV authorized diagnostic components (4 snapshot + `revankar2026mirage`), and four contain unbound quantitative defense assertions. The 20 evaluated-mitigation families and contextual comparators contribute **39 source-bound result records** (33 in the baseline snapshot plus 6 from the four October 21 mitigation additions) and **78 utility/cost field positions**. Table VIII organizes the eight intervention families by threat polarity (Types I–III), receiving view and deployment boundary.

VI-B Within-family and within-cohort record comparisons

While the machine-readable audit retains all $\binom{33}{2} = 528$ baseline pairs for completeness, 426 pairs cross unrelated mechanism cohorts and are outside scope by construction. Focusing on the **13 within-family pairs** (multiple records inside the same paper) and **102 within-cohort related pairs** (66 traffic-envelope, 28 cache-service, 3 behavioral-humanization, 3 generator-fingerprint, 1 local-memory, 1 fixed-instruction; Supplement S8) reveals why paper-level comparisons fail:

- Even within the **13 same-family pairs** (plus 2 same-family pairs in the additions: `CACHEPRUNE-selective` vs. `CACHEPRUNE-context` and `OTRO-unpadded` vs. `OTRO-epochpad`), nearly half (6/13 baseline; 7/15 full) measure different primitives, targets or cost objects (e.g., Early Bird's K-prefix oracle simulation vs. its GPTCache semantic prototype; SpliceDefense's CTBF signal suppression vs. QCP-only prefill cost; OTRO's unpadded TTFT vs. derived epoch-padding cost).
- Among the seven aligned-outcome same-family pairs, four evaluate different collection or execution populations (e.g., Dangol's stored-capture feature ablation at 0.17 accuracy vs. live loopback OHTTP at 0.30 accuracy) and three lack a verified matched-test binding, so none licenses cross-record subtraction as a single paired deployment effect.
- Across the **102 related-cohort pairs**, only 16 (15.7%) support a source-qualified descriptive comparison, whereas 80 (78.4%) exhibit positively established receiver, target or cost-object mismatches and 6 (5.9%) remain unresolved (dual-coded at 94.0% agreement, $\kappa = 0.916$).

VI-C Nine-item split reporting audit across 20 mitigation families

To avoid conflating component studies with end-to-end agent evaluations, Table IX splits Check 4 into **4a (D_1 protected-condition fitting)** and **4b (D_2 matched clean-vs-adapted testing)**, and splits Check 6 into **6a (defended inference effect)**, **6b (task or component utility)** and **6c (mechanism or protocol cost)** across the 16 baseline and all 20 evaluated-mitigation families.

SoK Takeaway 2 (The Component-vs-Workflow Reporting Gap). Across all 20 evaluated-mitigation families (Table IX), 85% (17/20) bind defended inference outcomes (Check 6a) and 55% (11/20) bind component or protocol cost (Check 6c), yet only 15% (3/20) bind task or component utility (Check 6b), only 10% (2/20: `uitraces2026`, `dangol2026workflow`) bind matched D_2 adaptation contrasts (Check 4b), and only a single study (`wu2026cacheprune` [12]) jointly binds 6a, 6b and 6c on the same operating point.

VII Match Transfer Claims to the Generator

VII-A Different tests rule out different explanations

A fingerprint is generated by a model interacting with tasks, prompts, tools, browser state and serving infrastructure. A holdout establishes portability along the axis it changes: new tasks,

TABLE VII

Deployment judgments, positive reuse conditions and applicable boundaries across the three checks. Direct evidence tests the named branch; extensions address length gradients, realistic cover policies and clean-versus-adapted training.

Decision check	Direct support / extension / background	Judgment after binding	Positive license and remaining bridge
1. Protect the final stream	Direct: NetEcho IV-C–E/Fig.5; SplitDecoy 5.1–5.3 (backward gradient support). Mechanism demo & gradient: our two-link TLS test and bucketed length-sensitivity sweep.	An upstream-view or forward-only result does not certify a downstream emitter or backward return path.	Keep the result for the tested projection. Verify protected-only postprocessing (Proposition 1), or evaluate the final hop; bucketed terminal framing trades byte overhead ($0.91\times$–$2.18\times$) against target length sensitivity.
2. Validate cover at execution	Direct: WRA 8.1/Table8 (read-only privacy decoys); AHB 5.2.3/Table1/E.3 (bot-evasion GUI touches). Mechanism demo & extensions: 24 synthetic tasks and 115 retail tasks (97 eligible) across discard, shadow, pure read, state-idempotent address, item self-write, decoy-account and planner-nonoverlap routes.	WRA and AHB differ in both polarity (privacy vs. bot evasion) and action risk (discarded read queries vs. live GUI clicks). Even payload-idempotent item writes can mutate workflow status (`pending (item modified)`).	Keep WRA's domain-view privacy result. Discard, shadow, pure reads and true state-idempotent writes preserve task state; live writes require dispatch-time authorization and status-transition checks.
3. Match adaptation and cost	Direct: UI Traces 6.1 (D_2 delayed-trace refit); S4 archive reanalysis ($+0.1503$ nats); Controlled E3 (D_0 vs. D_2 under offset/stochastic padding: $+12.9$ to $+50.0$pp gain). Positive local cases: CachePrune 5; OTRO VII. Extensions: Early Bird, KVGov, SpliceDefense.	Evaluating a clean-trained (D_0) attacker on shifted/padded traffic overstates protection; component microcosts do not price whole-service reuse loss.	Require matched D_2 evaluation on the same defended test set when adaptation is at issue, and bind each cost to its measured mechanism and workload.

TABLE VIII

Eight intervention families organized by threat polarity (Type I: confidentiality protection; Type II: provenance/identity attribution; Type III: bot-detection evasion), receiving view and supported deployment judgment. Because objectives and risk magnitudes differ, these rows are not a common efficacy ranking.

Intervention & polarity	Evaluated view, target and source	Established result and applicable boundary
Padding / batching (Type I: confidentiality)	Network packet lengths and groups; topic inference. NetEcho and Whisper Leak [7, 28].	Collected padding traces retain inference signal; packet-group batching is evaluated by replay. A protected upstream length view does not cover downstream re-emission or residual grouping. Live incremental cost remains NR-R.
Constant-rate / transport cover (Type I: confidentiality)	Network workflow fingerprint; Dangol's OHTTP testbed [26].	The co-located loopback setting yields 0.30 recovery at about $13\times$ bytes and $11\times$ latency. Transformed-capture results are separate; neither result supplies objective agent-task utility.
Concurrent query decoys (Type I: confidentiality)	Destination/domain observer; private prompt and trait inference. WRA [6].	Real/decoy research prompts execute in parallel as read-only queries whose decoy answers are discarded locally; interleaved-domain evaluation reduces one-decoy E_{func} from 0.770 to 0.610. Terminal decoy utility/cost are NR-R.
Action humanization (Type III: bot-evasion)	Mobile GUI touch traces; evading human–agent bot detection. AHB [9].	Unlike WRA's read-only privacy decoys, AHB's `Fake` mode dispatches live mobile GUI touches to evade platform bot detectors, dropping Trip Planning success from 0.75 to 0.15. Non-Fake `History+Long` (0.7143 success) avoids GUI mutation.
Cache isolation / keying (Type I: confidentiality)	Co-tenant prefix timing; SafeKV, KVGov and CachePrune [27, 10, 12].	SafeKV reports post-trigger AUC near 0.5 and separate TTFT/throughput comparisons. KVGov's HMAC median $1.3\,\mu$s prices key computation, excluding lost reuse. CachePrune jointly binds marked-token protection, QA/summarization utility and serving performance.
Cache timing equalization (Type I: confidentiality)	Co-tenant cache-fusion timing; SpliceDefense [11].	Constant-Time Boundary Fusion (CTBF) suppresses the tested signal over 15 tasks/75 steps. Quantized Chunk Padding (QCP) adds mean 7.5 tokens and $<$ 5ms/$<$ 1% prefill time; this does not price combined deployment.
Timestamp perturbation (Type II: attribution)	Recorded website action metadata; model/agent attribution. UI Traces [5].	Fitting on delayed traces (D_2) recovers substantial attribution performance under offline timestamp edits that retain action types/order. Live execution delay and task outcomes are not measured by the trace transformation.
Oblivious / unshared memory (Type I: confidentiality)	Host or local resource observations; TDXRay, Gao et al. and OTRO [54, 55, 18].	TDXRay measures oblivious-map lookup cost; Gao measures loading/memory cost after disabling zero-copy. OTRO reduces conditional access-count information (3.94 to 0.04 bits) with separate unpadded TTFT (4.59%) and epoch-padding (2.8ms) bounds.

Authorized operator diagnostics (Type IV: ClawGuard, cycle detection, LumiMAS, LLM-serving RCA and MIRAGE) are baseline telemetry rather than privacy attacks or evasion defenses, and are cataloged separately.

browser configurations, network topologies and hardware are distinct deployment tests. Supplement S2 maps each dependency to its supporting holdout.

UI Traces fixes a browser/action harness while testing tasks and environments. FP-Agent combines behavior with static browser attributes; shared visitor proxies are not authenticated independent people or hosts [5, 19]. Task separation can remove memorization of those task instances while retaining configura-

TABLE IX
Nine-item split reporting audit over the 16 original evaluated-mitigation families (and 20 total including the four October 21 mitigation additions in parentheses). Splitting Check 4 (D1 vs. D2) and Check 6 (inference, utility, cost) exposes component-level variance without requiring every study to run an end-to-end deployment evaluation.

Audit item	Bound	Partial	NR-R	NR-V	NA
1. Target & protection polarity	16 (20)	0 (0)	0 (0)	0 (0)	0 (0)
2. Receiver fields & linkage	13 (17)	3 (3)	0 (0)	0 (0)	0 (0)
3. Placement & action dispatch	13 (16)	2 (3)	0 (0)	1 (1)	0 (0)
4a. Protected-condition fit (D1)	4 (4)	1 (1)	0 (0)	4 (6)	7 (9)
4b. Matched adapted test (D2)	2 (2)	2 (2)	0 (0)	5 (7)	7 (9)
5. Workloads & generator shifts	14 (18)	2 (2)	0 (0)	0 (0)	0 (0)
6a. Defended inference effect	14 (17)	0 (1)	2 (2)	0 (0)	0 (0)
6b. Task or component utility	2 (3)	2 (3)	10 (11)	0 (0)	2 (3)
6c. Mechanism or protocol cost	10 (11)	1 (3)	4 (5)	0 (0)	1 (1)

Bound: explicitly established for the scoped claim. Partial: a supported element coexists with a proxy or unlinked operating point (e.g., AHB D1-code without verified Table 1 D1-run; WRA Table 11 visibility utility separate from Tables 8–9 decoys). Only one family across the expanded 20-family mitigation set (`wu2026cacheprune`) jointly binds 6a, 6b and 6c on the same operating point. Independent two-coder agreement over the 144 baseline cells is 93.1% ($\kappa = 0.876$, 95% CI $[0.798, 0.943]$).

tion identifiers. This is not proof of an invalid original split; it bounds portability. The traffic benchmark separately tests generating topology, so its shift is a different test rather than a stronger score on the same estimand [42].

LeakyLMs illustrates the boundary for system-property rather than agent identity. Its deployment probe observes streaming events through an ordinary client API. Its architecture branch additionally assumes known GPU type, same-class calibration and single-GPU execution [56]. Remote architecture inference therefore does not establish hardware-agnostic inference. The joint search in its remote example ranks the true configuration 28/2068, distinct from a conditional parameter search or a near match; those outcomes must not be collapsed into universal exact recovery. Source-reported local architecture generalization and remote deployment signatures remain positive evidence under their own assumptions.

VII-B Representation increment is not portability

Within a fixed observer and test population, coarse counts versus sequence features test whether the latter improve a specified predictor. WRA already uses ordered domains before adding timing; Kang changes class sets across some conditions [6, 40]. These test different contrasts from an order-only effect. The supplementary archive example fixes labels and units and finds a 0.3447-nat sequence increment under archive-receiver ordering. Its small common-task control leaves task-distribution explanations unresolved (Supplement S4).

Adjacent coding-agent PR attribution depends on repositories, submission pathways and artifact generation. Its mixed-feature result does not isolate an auxiliary-only C3 view; inspected code computes weighted F1 and reduces features before cross-validation, but the exact paper-run binding remains unverified [13]. We neither rewrite its headline score nor quantify optimism. WildAuth is adjacent under the same rule; input/partition ambiguities do not supply a model-independent response-only privacy claim [14].

VII-C Resulting claim hierarchy

Task-specific identification, task-disjoint identification in a fixed harness, configuration/topology transfer and hardware-calibrated architecture inference require different evidence. Move between them by changing the relevant generator while preserving target labels and the receiver contract. For a representation increment, compare representations on identical units and disclose predictor/selection restrictions. This claim-to-holdout rule lets a reader reuse each author test for the shift it measures.

VIII CONTROLLED BOUNDARY TESTS: REAL TLS STREAMS AND STATEFUL AGENT TOOLS

To test the mechanisms identified in Cases 1–3 under controlled local interventions without extrapolating ecosystem prevalence, we execute two complementary experimental suites (`experiments/revision-m1-m8/run_sp2027_experiments.py`): (1) **real loopback TLS 1.2 socket replays** across 48 unmodified `gpt-6-luna` explanations spanning four natural task-granularity regimes ($d \in [0.25, 10.4]$) and multi-feature D_0-versus-D_2 adaptive classifiers (Checks 1 and 3; Table X); and (2) **joint privacy (D_0/D_2 observer inference) and utility (state-machine preservation) evaluations** across 24 synthetic plans and all **115 τ-bench retail reference tasks** (97 tasks with an eligible pending order, $\times 3$ seeds $\times 2$ insertion positions) under nine baseline and oracle-free realistic cover policies (Checks 2 and 3; Section VIII-C and Table XI).

VIII-A Check 1 & Check 3 on real TLS 1.2 streams: natural task-granularity gradient

For each of 24 public topics (12 training, 12 disjoint test topic clusters), `gpt-6-luna` generates a 1-sentence brief explanation (105–160 UTF-8 bytes) and a 6–8 sentence expanded explanation (812–1,249 bytes; 48 saved outputs). An upstream origin transmits each response over a real loopback TLS 1.2 connection (`ECDHE-RSA-AES128-GCM-SHA256`) to a frontend that decrypts, strips upstream padding and re-emits chunks over a second terminal TLS 1.2 connection captured by a transparent TCP relay. Every trial verifies exact plaintext SHA-256 recovery and parses actual TLS record type 23 application frames.

In the baseline mechanism demonstration (Table X, Panel A), fixed 16-frame upstream padding (16,848 wire bytes vs. 721B unpadded mean; 23.37× overhead) equalizes upstream size observations (50.0% accuracy), while the unpadded 128B-chunked terminal emitter restores 100.0% accuracy until terminal padding is added.

To evaluate how terminal framing behaves across workloads with naturally different length separability—without artificial mid-sentence character truncation—Panel B of Table X evaluates power-of-two terminal TLS bucketing ($B \in \{256, 512, 1024\}$B) across **four natural inference targets** on the saved corpus:

- T_1 **(Directive verbosity: 1-sentence brief vs. full 6–8 sentence response, Cohen's $d = 10.4$):** Because class lengths are separated by $\Delta\mu = 875$B, 256B (1.19× wire bytes) and

TABLE X

Real loopback TLS 1.2 (`ECDHE-RSA-AES128-GCM-SHA256`) mechanism demonstrations and stress extensions on the 48 saved `gpt-6-luna` outputs (12 train / 12 test topic clusters). Panel A demonstrates Check 1 re-emission. Panel B evaluates power-of-two terminal bucketing across four unmodified natural task regimes with varying length separation (Cohen's d). Panel C evaluates Check 3 (D_0 clean-trained vs. D_2 defended-trained attackers across training budgets $k \in \{4, 12\}$ pairs and multi-feature streams on identical defended test outputs; 95% bootstrap CIs in brackets).

A. Check 1 mechanism demo: two-link TLS re-emission (T_1, $d = 10.4$)

Padding placement	Upstream acc.	Terminal acc.	Wire bytes (ratio)
None	100.0%	100.0%	721 (1.00×)
Upstream link only	50.0%	100.0%	721 (1.00×)
Both links (16-frame cap)	50.0%	50.0%	16,848 (23.37×)

B. Natural task-granularity gradient across terminal TLS bucketing (D_2)

Natural inference target (Cohen's d)	Unpadded	Bucket 256B	Bucket 512B / 1024B
T_1: Directive verbosity (1 vs. 6–8 sent., $d = 10.4$)	100.0%	100.0% (1.19×)	100.0% / 70.8% [58.3, 83.3]
T_2: Short vs. medium (1 vs. 2 sent., $d = 3.1$)	100.0%	87.5% [75.0, 100]	50.0% (0.87×) / 50.0%
T_3: Medium vs. extended (2 vs. 3 sent., $d = 1.4$)	91.7%	62.5% [50.0, 75.0]	50.0% (0.91×) / 50.0%
T_4: Eng. vs. ecology domain (full text, $d = 0.25$)	45.8%	45.8% (1.19×)	45.8% (1.51×) / 45.8%

C. Check 3 extension (E3): clean (D_0) vs. adaptive (D_2) TLS attacker (T_1)

Terminal defense ($n = 24$ test)	Clean D_0	D_2 ($k = 4/12$)	Gain $\Delta(D_2 - D_0)$
Deterministic offset (+512B, 1.87×)	50.0%	100.0% / 100.0%	+50.0pp [+50.0, +50.0]
Bucketed 1024B quantum (1.94×)	50.0%	70.8% / 70.8%	+20.8pp [+8.3, +33.3]
Stochastic $+U(0, 512\text{B})$ (1.44×)	86.4%	99.9% / 99.9%	+13.5pp [+10.7, +16.3]
Stochastic $+U(0, 1024\text{B})$ (1.88×)[a]	68.2%	90.2% / 89.3%	+21.1pp [+17.3, +24.8]
Constant cap (16,848B, 23.37×)	50.0%	50.0% / 50.0%	0.0pp [0.0, 0.0]

[a]Multi-feature D_2 classifier (using TLS record count, total payload bytes and final-record remainder) reaches 89.9% under $+U(0, 1024\text{B})$. All streams preserve exact UTF-8 plaintext SHA-256 hashes across real TLS 1.2 sockets.

512B (1.51×) bucketing leave T_1 separable (100.0% accuracy). Moving to 1,024B bucketing (1.94× wire bytes) drops D_2 accuracy to **70.8%** (95% topic-cluster bootstrap CI $[58.3\%, 83.3\%]$), and constant capping (23.37×) reaches **50.0%**.

- T_2 **(Short vs. medium exposition: 1-sentence vs. 2-sentence complete sentences, $d = 3.1$) and T_3 (Medium vs. extended exposition: 2-sentence vs. 3-sentence complete sentences, $d = 1.4$):** At 256B bucketing, T_2 and T_3 drop to **87.5%** (CI $[75.0\%, 100\%]$) and **62.5%** (CI $[50.0\%, 75.0\%]$), respectively. At 512B bucketing (0.87× and 0.91× the baseline full-response wire budget because fewer TLS record headers are emitted), both T_2 and T_3 collapse to the **50.0%** chance baseline.

- T_4 **(Engineering/infrastructure vs. ecology/environment domain classification on full unmodified responses, $d = 0.25$):** Because semantic topic domain is nearly orthogonal to response length when verbosity is matched, even unpadded terminal streams yield **45.8%** test accuracy (CI $[25.0\%, 66.7\%]$, indistinguishable from 50% chance).

VIII-B Check 3 on real TLS 1.2 streams (Experiment E3): $D_0 \to D_2$ adaptation rebound

Panel C of Table X compares a **clean-trained classifier (D_0, fitted on unpadded TLS streams: threshold 623B)** against **defended-trained adaptive classifiers (D_2, fitted on $k = 4$ or $k = 12$ protected training topic pairs, plus a 3-feature regularized linear classifier over TLS record count, total payload bytes and final-record remainder)** on the **identical defended test set** ($n = 24$ outputs across 12 test topic clusters):

- **Bucketed 1024B framing (1.94× wire bytes):** Evaluating only the clean-trained attacker D_0 makes 1,024B bucketing appear completely indistinguishable (**50.0%** accuracy, because padding even a 1-sentence response to 1,024B produces 1,082B > 623B, causing D_0 to predict class 1 constantly). However, retraining D_2 on as few as $k = 4$ defended topic pairs shifts the threshold between the 1-quantum (1,082B) and 2-quantum (2,164B) modes, rebounding test accuracy to **70.8%** ($\Delta = +20.8$**pp**, 95% CI $[+8.3, +33.3]$).

- **Stochastic chunk-tail padding $+U(0, 512\text{B})$ (1.44×) and $+U(0, 1024\text{B})$ (1.88×):** Under $+U(0, 512\text{B})$, D_0 drops to **86.4%** while D_2 ($k = 4$ or 12) rebounds to **99.9%** ($\Delta = +13.5$**pp**, CI $[+10.7, +16.3]$). Under $+U(0, 1024\text{B})$, D_0 drops to **68.2%**, whereas D_2 rebounds to **90.2%** ($k = 4$) and **89.3%** ($k = 12$, $\Delta = +21.1$**pp**, CI $[+17.3, +24.8]$; 3-feature linear D_2: **89.9%**).

- **Deterministic offset (+512B, 1.87×) and Constant cap (16,848B, 23.37×):** Under +512B offset, D_0 scores **50.0%** while D_2 recovers **100.0%** (+50.0pp); under constant capping ($I(S; Z) = 0$), both D_0 and D_2 remain at **50.0%** ($\Delta = 0.0$pp).

SoK Takeaway 3 (Natural Length Entropy & D_2 Framing Calibration). Terminal framing cost is governed by the target's natural length separation (d): 512B bucketing eliminates moderate/low exposition leakage ($d \leq 3.1$) below baseline wire cost, whereas high-separation verbosity ($d = 10.4$) retains 70.8% leakage even under 1,024B bucketing once the attacker retrains (D_2: +20.8pp over D_0).

VIII-C Checks 2 & 3 on stateful tools: 24 synthetic plans and 115 τ-bench retail tasks

We next evaluate cover execution semantics and the privacy–utility trade-off across stateful tool environments. First, as a controlled 24-task synthetic baseline (12 inventory, 12 calendar tasks using saved `gpt-6-luna` plans; Supplement S9), `discard`, `isolated_shadow` and `read_only` routes preserve 24/24 task successes and exact state equality by architectural construction, whereas live cover writes to overlapping or protected bystander resources reduce complete task success to 9/24 (37.5%, −62.5pp, 95% CI $[-79.2, -41.7]$; 15/24 narrow goal completions minus 6 protected-resource violations).

To test realistic cover policies and joint privacy–utility trade-offs on a production-grade tool suite, we extend the experiment to Sierra's pinned τ-bench retail environment (16 retail tools, 115 public test reference tasks crossed with 3 seeds and 2 insertion positions, `before` vs. `after` the reference program). Because seeds and insertion positions are repeated measures on the same 115 tasks, **the effective sample size is 115 tasks**: specifically, **97 eligible tasks** in which the task user owns ≥ 1 initially `pending` order (291 task-seed units per position), and **18 ineligible tasks** with zero pending orders where no cover action executes and reward is mechanically 100.0% (which dilutes full-census means). Table XI reports both task utility (`native_reward` and task-target state equality `gold_touched_state_equal`) and **observer cancellation-intent inference accuracy** (D_0 clean-trained vs. D_2 defended-trained linear classifiers predicting whether the user's real workflow executed a pending-order cancellation from live tool-dispatch observations).

1. Eligible-subset effects and why post-insertion (`after`) reward exceeds pre-insertion (`before`) In Panel C of Table XI, blind live cancellation (`cancel_pending_order` on a random pending order of the user) reduces mean native reward on the **97 eligible tasks** from 100.0% to **11.34%** when inserted *before* the reference program (−88.66pp, 95% task-bootstrap CI $[-94.16, -82.13]$; error-free eligible $n = 82$: **9.76%**) and **41.24%** when inserted *after* it (−58.76pp, CI $[-67.70, -49.83]$; error-free eligible $n = 82$: **38.21%**). Including the 18 ineligible tasks mechanically shifts the 115-task census means to 25.22% (`before`) and 50.43% (`after`).

Inspecting tool invocation outcomes explains the 41.24% versus 11.34% post/pre-insertion gap completely:

- **Before insertion (100.0% cover call success):** All 291 eligible task-seed units target an initially `"pending"` order, so `cancel_pending_order` **succeeds and mutates live state in 291/291 (100.0%) of eligible units**. Native reward drops to 0.0 in 258/291 (88.66%) units, and remains 1.0 in **33/291 (11.34%) units (across 12 tasks)** only because in those 12 tasks the reference program itself was tasked with cancelling that exact order with reason `"no longer needed"`—so pre-insertion cover cancelled it first, causing the reference program's subsequent `cancel_pending_order` call to fail with `Error: non-pending order cannot be cancelled` while leaving the final database snapshot identical to baseline. As argued in Section V, this illustrates our **analytical design argument** that terminal snapshot scorers are path-oblivious, rather than an empirical discovery of unobserved user consent.

TABLE XI
Joint utility and privacy evaluation across 115 τ-bench retail reference tasks (×3 seeds ×2 positions): eligible-subset ($n = 97$ tasks with an initially pending order) versus full-census ($n = 115$, including 18 ineligible tasks where no cover executes), oracle-free realistic cover policies, and D_0 versus D_2 cancellation-intent inference accuracy (percent).

Cover route / policy (Before / After)	Eligible ($n = 97$) Reward	Eligible ($n = 97$) Target eq.	Observer acc. (elig.) Clean D_0	Observer acc. (elig.) Adapted D_2
A. Non-mutating baseline routes (all-115 native reward = 100.0%)				
No cover / Discard / Shadow (Before & After)	100.0	100.0	100.0	100.0
Pure read (`get_order_details`, Before & After)	100.0	100.0	100.0	100.0
B. Realistic live cover policies (oracle-free instruction parser & idempotence tests)				
State-idempotent address write (Before / After)[a]	100.0 / 100.0	100.0 / 100.0	100.0	100.0
Payload-idempotent item self-write (Before)[b]	40.55	70.10	100.0	100.0
Payload-idempotent item self-write (After)[b]	67.70	97.25	100.0	100.0
Instruction-aware cover (Before, oracle-free)[c]	35.05	78.35	51.02	73.47
Instruction-aware cover (After, oracle-free)[c]	46.39	89.69	51.02	71.43
Decoy-account live cancel (Before & After)[d]	100.0†	100.0	22.45	71.43
C. Blind live cancellation of user's pending order (`cancel_pending_order`)				
Blind live cancel: Before (100% call success)[e]	11.34	62.54	22.45	71.43
Blind live cancel: After (58.76% call success)[e]	41.24	92.44	22.45	68.03

Columns: *Reward* is τ-bench native reward on the 97 eligible tasks; *Target eq.* is `gold_touched_state_equal`; *Clean* D_0 and *Adapted* D_2 measure a live tool-dispatch observer's accuracy in inferring whether the user's real workflow executed a pending-order cancellation.

[a] Overwrites current shipping address in-place; 0% tool error before, 41.24% rejection after.

[b] Maps first item to its own `item_id` (Δprice = 0), which transitions `status` to `"pending (item modified)"` in 59.45% (before) and 32.30% (after) of eligible units (all-115 reward: 49.86% before, 72.75% after).

[c] Parses only `task.instruction` (zero access to `task.actions`) to select an unmentioned pending order when available (70.10% of eligible tasks; all-115 reward: 45.22% before, 54.78% after).

[d†] Preserves 100.0% of the active user's account state (`user_orders_state_equal = 100%`) and 100.0% of task-touched state; unscoped whole-DB hash reward is 0.0% (eligible) / 15.65% (all-115) because the decoy account resides in the shared `orders` table.

[e] All-115 blind live cancel reward is 25.22% (before) and 50.43% (after) due to the 18 ineligible tasks (100% reward). In After, 41.24% (120/291) of cover calls are rejected with `Error: non-pending order cannot be cancelled` because the reference program already modified (79) or cancelled (41) the order.

- **After insertion (58.76% cover call success vs. 41.24% tool rejection):** During the reference program's prior execution, the reference program itself modifies the selected order's items (`modify_pending_order_items`, setting `status="pending (item modified)"` in 79 units) or cancels the order (`cancel_pending_order`, setting `status="cancelled"` in 41 units) in **41.24% (120/291) of eligible units**. Because τ-bench rejects cancellation of any order whose status is no longer strictly `"pending"`, the post-insertion cover call **fails with `Error: non-pending order cannot be cancelled` in 41.24% (120/291) of eligible units** (leaving state untouched and reward at 100.0% in all 120 units) and **succeeds in only 58.76% (171/291) of eligible units**, where it corrupts final state and drops native reward to 0.0% in all 171/171 units.

2. The Idempotence Illusion and the Account-Scope Hazard across realistic cover policies Panel B of Table XI evaluates four realistic cover designs across the 97 eligible tasks, exposing three non-trivial systems trade-offs:

1. **The Idempotence Illusion (`live_idempotent_address` vs. `live_idempotent_item_swap`):** Writing an order's current shipping address back via `modify_pending_order_address` overwrites the address dict in place without altering `status` or `payment_history`, preserving **100.0% native reward** (`before` and `after`). By contrast, calling `modify_pending_order_items` to map an order's first item to its *own identical* `item_id` (`new_item_ids=[item_id]`, Δprice $=$ \$0.00) is payload-idempotent on item values, yet in τ-bench's state machine any successful item modification transitions `order["status"]` from `"pending"` to `"pending (item modified)"` (blocking any subsequent modification or cancellation!) and appends a \$0.00 refund record. It mutates state in **59.45% (173/291)** of `before` eligible units, collapsing eligible native reward to **40.55%** (`before`, CI $[31.62\%, 50.17\%]$) and **67.70%** (`after`, CI $[59.10\%, 76.29\%]$), while providing **0% privacy protection** against a cancellation-verb observer (100.0% D_0 and D_2 accuracy).

2. **The Account-Scope Hazard under Oracle-Free Instruction Parsing (`live_instruction_aware`):** To test realistic context-aware cover without oracle access to future reference actions (`task.actions`), `live_instruction_aware` parses *only* the user's natural-language prompt (`task.instruction`) and initial order table, selecting a pending order whose ID and item names are not mentioned in `task.instruction` (available in 70.10% [68/97] of eligible tasks) and falling back to state-idempotent address writes otherwise. Because it avoids orders mentioned by the user, **task-target state preservation (`gold_touched_state_equal`) rises from 62.54% (blind cancel) to 78.35% (`before`, CI** $[70.10\%, 86.60\%]$**) and 89.69% (`after`, CI** $[83.51\%, 94.85\%]$**)!** Yet because cancelling even an *unmentioned* pending order on the same user's account deletes a real bystander order owned by that user, whole-account `native_reward` remains **35.05% (`before`) and 46.39% (`after`)**.

3. **Decoy-Account Isolation and the $D_0 \to D_2$ Observer Rebound (`live_decoy_account`):** Routing live `cancel_pending_order` cover calls to a designated decoy user account preserves **100.0% of the active user's account state (`user_orders_state_equal = 100.0%`)** and **100.0% of task-touched state**. On the privacy axis, injecting live cancellations reduces a clean-trained D_0 observer's accuracy from **100.0% to 51.02%** (`live_instruction_aware`) and **22.45%** (`live_decoy_account` / `live_mutation`). However, when the observer retrains on the defended tool-dispatch distribution (D_2), it exploits session write counts and payload byte lengths to rebound to **73.47% (`before`) / 71.43% (`after`)** under `live_instruction_aware` (+22.45pp gain) and **71.43% (`before`) / 68.03% (`after`)** under `live_decoy_account` and `live_mutation` (+48.98pp and +45.58pp adaptation rebound).

SoK Takeaway 4 (The Idempotence Illusion & Joint Privacy–Utility Frontier). In stateful agent workflows, payload-idempotent tool calls (`new_item_ids=[item_id]`) can corrupt 59.45% of tasks via one-way status flags while yielding 0% verb-level privacy; oracle-free instruction parsing protects 78.35%–89.69% of task-touched state but still damages bystander orders on the user's account; and even when decoy-account isolation preserves 100% of user state, a D_2 adaptive observer recovers +48.98pp over a naive D_0 observer unless total write counts per session are equalized.

IX Implications, Ethical Boundaries and Limits

IX-A A nine-item deployment reporting checklist

To make future defense evaluations reusable across agent workflows without forcing every component paper to run an end-to-end benchmark, studies should report the nine split fields audited in Table IX: (1) hidden target and threat polarity (Types I–IV); (2) final receiver fields and session/document linkage permissions; (3) where protection terminates and whether cover reaches live tool/GUI dispatch; (4a) protected-condition fitting/calibration (D_1) and (4b) matched clean-versus-adapted testing (D_2) on identical defended units; (5) tested workloads and generator holdouts; and (6a) defended inference outcome, (6b) task or component utility (distinguishing task-touched state from whole-account and global state), and (6c) the specific mechanism or protocol cost object measured.

IX-B Open research problems implied by the systematization

Five concrete research problems emerge from our repository and boundary experiments:

1. **End-to-end target-oblivious streaming protocols:** How can content-aware SSE/WebSocket renderers and split-model backward passes enforce the Markov condition of Proposition 1 ($I(S;Y \mid Z) = 0$) using adaptive bucketed framing calibrated to task length entropy ($d \in [0.25, 10.4]$)?

2. **Formal state-idempotence contracts for tool schemas:** Can MCP and tool-calling specifications distinguish pure reads, true state-idempotent overwrites (`modify_pending_order_address`), and status-mutating or ledger-appending writes (`modify_pending_order_items`) so cover dispatchers can verify state neutrality before invocation?

3. **Constant-count decoy-account transactions against D_2 observers:** Because a D_2 observer rebounds from 22.45% to 71.43% accuracy on single-cover retail sessions by counting total writes per episode (Table XI), how can sandboxed decoy accounts equalize total write counts across sessions without exhausting shared database locks?

4. **Workload-level KV-cache reuse pricing:** What is the multi-turn cache-miss latency penalty of cryptographic namespace isolation (KVGov [10]) relative to selective sensitive-token pruning (CachePrune [12]) under realistic agent trajectories?

5. **Cross-generator invariance:** Which behavioural or traffic features survive simultaneous shifts in task family, browser configuration and multi-agent topology?

IX-C Dual-use, bot-detection evasion and ethical boundaries

Separating threat polarities (Types I–IV) exposes a critical dual-use and ethical boundary that is obscured when all side-channel interventions are labeled "privacy defenses." Type I defenses (such as TLS/OHTTP record padding in NetEcho and Dangol, selective KV sharing in CachePrune, and local read-only query decoys in WRA) protect legitimate users from passive network profiling or co-tenant prompt extraction. By contrast, Type III action humanization (AHB [9]) is explicitly designed to make automated GUI agents indistinguishable from human users so they bypass platform bot detection and anti-automation controls.

Deploying behavioural mimicry or synthetic GUI touch injection to evade bot detection carries two significant risks: (1) **erosion of platform accountability and abuse controls**, as websites and mobile platforms rely on behavioural telemetry (UI Traces, FP-Agent, WebAgents [5, 19, 45]) to defend against credential stuffing, automated scraping and fraud; and (2) **third-party state and safety hazards**, as injecting live synthetic actions into production interfaces risks triggering unauthorized transactions or corrupting user state (demonstrated by AHB's 0.75 to 0.15 Trip Planning collapse and our retail state-mutation findings). System designers seeking legitimate Type I user privacy should therefore prefer protocol-level transport shaping (TLS/OHTTP bucketing), shadow-clone execution, or isolated decoy accounts rather than deceptive GUI manipulation against third-party services.

IX-D Threats to validity

Purposive corpus and keyword-query overlap Our 82-family corpus is assembled via purposive seed selection, venue screening and one-hop citation snowballing from 40 seeds, supplemented by the completed 565-record October 21 keyword search frame (Table II). Because the 24 fixed known papers are a core subset of the 40 seeds, the 17/24 and 25/60 query-return ratios measure lexical overlap between narrow Boolean queries and our seed-anchored collection rather than calibrated database recall.

Dual-coding scope Independent expert human dual-coding covers a 100-record stratified screening subsample ($\kappa = 0.886$), all 144 cells of the nine-item baseline audit ($\kappa = 0.876$), all 24 retrospective validity scenarios ($\kappa = 0.795$), and 50 record pairs / 150 comparability judgments ($\kappa = 0.916$).

Controlled boundary experiments Our loopback TLS 1.2 socket replays and τ-bench retail experiments replay saved `gpt-6-luna` outputs/plans and 115 public retail reference programs (97 with an eligible pending order) deterministically. They establish mechanism behavior, natural task-granularity framing trade-offs, D_0-versus-D_2 adaptation rebounds and tool state-machine side effects without claiming to measure remote WAN jitter or autonomous multi-turn planning errors.

X Conclusion

Protecting an isolated LLM component does not automatically protect an autonomous agent workflow. By organizing 82 study families (58 core, 24 adjacent) and 39 intervention result records (78 utility/cost fields) into a source-bound repository, this SoK resolves apparent contradictions across the literature through three operational checks: bind the final target-bearing emitter and threat polarity (Check 1), validate cover against tool state-machine semantics (Check 2), and evaluate adaptive (D_2) observers alongside mechanism-specific costs (Check 3). On a 24-scenario retrospective deployment-transfer benchmark, applying this three-check procedure improves transfer decision accuracy from 29.2% (0% failure recall under deterministic headline-metric reuse) to 93.8% across two independent expert coders ($\kappa = 0.795$), while independent dual-coding across screening ($\kappa = 0.886$), split-check auditing ($\kappa = 0.876$) and pairwise comparability ($\kappa = 0.916$) confirms high coding reliability.

Real loopback TLS 1.2 replays across four natural task-granularity regimes ($d \in [0.25, 10.4]$) and joint privacy–utility evaluations across 115 τ-bench retail reference tasks (97 eligible) reinforce all three checks: (1) required terminal bucketing overhead scales with natural target length separability; (2) in stateful agent tools, payload idempotence does not imply state-machine idempotence (`modify_pending_order_items` self-writes break 59.45% of eligible pre-insertion tasks via status transitions, whereas state-idempotent address writes and decoy-account isolation preserve 100% user-account state); and (3) adaptive D_2 observers rebound by $+20.8$ to $+49.0$ percentage points over static D_0 observers across both padded TLS streams and live tool-dispatch traces.

APPENDIX A REPRODUCIBILITY AND NOTATION

The accompanying *Supplementary Evidence* and package directory provide eleven self-contained modules: S1 historical search records; S2 corpus/prior-work maps; S3 retained pilots; S4 public-trace reanalysis; S5 intervention inventory; S6 original conclusion sensitivity; S7 workflow comparison diagnostics and the 24-case retrospective validity benchmark; S8 the pairwise and nine-item split audit (with independent human dual-coding records); S9 controlled mechanism demonstrations and extensions (E1 length-sensitivity gradient, E2 synthetic plans, E3 D_0-vs-D_2 adaptive attacker, and T2c 115-task / 97-eligible-task retail baseline and realistic cover policies); S10 the completed 565-record search update and exact $60 \rightarrow 82$ reconciliation; and `experiments/revision-m1-m8/` containing all scripts, CSVs and JSON summaries for the M1–M8 revisions.

Executable acquisition record Table XII records the actual historical IEEE/ACM native queries (October 8–9, 2026). S10 prints the four Semantic Scholar bulk queries (`S1R`, `S2`, `S3`, `S4`) and two native arXiv queries (`ARXIV-A1`, `ARXIV-A2`) completed on October 21, 2026 (615 occurrences, 565 unique records), together with the pre-audit and post-audit reconciliation table (Table II).

TABLE XII
Executed native queries. S1 retains the full export accounting; Q4 was issued only on IEEE and not exported in the original acquisition.

ID	Exact query
Q1	`("large language model" OR LLM) AND ("side channel" OR "side-channel" OR "timing attack")`
Q2	`(agent OR agentic) AND ("traffic analysis" OR fingerprinting OR "metadata leakage" OR "side channel" OR "side-channel")`
Q3	`("KV cache" OR "prompt caching" OR "speculative decoding") AND (privacy OR leakage OR attack)`
Q4	`("browser agent" OR "research agent" OR "tool calling" OR "model context protocol" OR "multi-agent") AND (timing OR fingerprinting OR leakage)`
Q4b	`(("browser agent" OR "research agent" OR "tool calling" OR "model context protocol" OR "multi-agent") AND (timing OR fingerprinting OR leakage) AND ("large language model" OR LLM))`
Q5	`("language model" OR LLM) AND ("traffic shaping" OR "cache isolation" OR padding OR "side-channel defense")`
Q6	`("language model" OR chatbot OR "AI assistant" OR "generative AI") AND ("side channel" OR "side-channel" OR "traffic analysis" OR fingerprinting OR "timing leakage")`

TABLE XIII
Reading key for the supplied records. Prose uses full meanings; codes support joins.

Notation	Meaning
SCOPE	Secret/target, Channel, Observer, Pipeline, Exploitation goal.
Types I–IV	Confidentiality, Provenance attribution, Bot-detection evasion, Authorized diagnostics.
Legacy A/B	Workflow-origin (A) / runtime-and-application-inherited (B) signal origins.
C1–C5	Five core eligibility conditions in Section II.
P1–P8	Hardware, serving, transport, application, orchestration, tools, environment, multi-agent communication.
D0 / D1 / D2	Clean-trained attacker / Protected-condition fitting / Matched D_0-vs-D_1 comparison on the same defended test set.
NR-R / NR-A	Unreported in inspected scope / unavailable material.
NR-V / NA	Unverified binding / structurally inapplicable.

REFERENCES

[1] R. Weiss, D. Ayzenshteyn, G. Amit, and Y. Mirsky, "What was your prompt? a remote keylogging attack on ai assistants," in *33rd USENIX Security Symposium*, pp. 3367–3384, USENIX Association, 2024.

[2] G. Wu, Z. Zhang, Y. Zhang, W. Wang, J. Niu, Y. Wu, and Y. Zhang, "I know what you asked: Prompt leakage via kv-cache sharing in multi-tenant llm serving," in *Network and Distributed System Security Symposium (NDSS)*, 2025.

[3] L. Song, Z. Pang, W. Wang, Z. Wang, X. Wang, H. Chen, W. Song, Y. Jin, D. Meng, and R. Hou, "The early bird catches the leak: Unveiling timing side channels in llm serving systems," *IEEE Transactions on Information Forensics and Security*, vol. 20, pp. 11431–11446, 2025. Consulted arXiv:2409.20002v5; archived access 18 October 2026.

[4] Y. Zhang, X. Deng, Z. Gu, Y. Chen, K. Xu, Q. Li, and J. Wu, "Exposing llm user privacy via traffic fingerprint analysis: A study of privacy risks in llm agent interactions," *arXiv preprint arXiv:2510.07176*, 2025.

[5] W. Lugoloobi, S. Marro, J. Magomere, J. Wright, and C. Russell, "Known by their actions: Fingerprinting llm browser agents via ui traces," *arXiv preprint arXiv:2605.14786*, 2026. Consulted arXiv:2605.14786v1; archived access 18 October 2026.

[6] H. Jeong, M. Teymoorianfard, A. Kumar, A. Houmansadr, and E. Bagdasarian, "Network-level prompt and trait leakage in local research agents," in *35th USENIX Security Symposium*, pp. 6485–6504, USENIX Association, 2026.

[7] Z. Zhang, G. Wu, S. Deng, S. Wang, and Y. Zhang, "Netecho: From real-world streaming side-channels to full llm conversation recovery," *arXiv preprint arXiv:2510.25472*, 2025. Consulted arXiv:2510.25472v1; archived access 18 October 2026.

[8] G. Politis and E. Pappas, "Privacy failure in split-llm training, the returned gradient nullifies the decoys," *arXiv preprint arXiv:2609.04382v1*, 2026. Consulted 2609.04382v1; source-scoped access 21 October 2026.

[9] J. Zhu, L. Yang, R. Shan, C. Zheng, Z. Zheng, W. Liu, Y. Yu, W. Zhang, and J. Lin, "Turing test on screen: A benchmark for mobile GUI agent humanization," *arXiv preprint arXiv:2604.09574v1*, 2026. Consulted arXiv:2604.09574v1; archived access 18 October 2026.

[10] T. C. Addagada, "Governing the kv cache: Preventing timing side-channel leakage in multi-tenant llm inference," *arXiv preprint arXiv:2608.09225*, 2026. Consulted arXiv:2608.09225v1; archived access 19 October 2026.

[11] H. Sun, S. Liu, S. Ma, J. Li, M. Xiao, and W. Jiang, "Agent-assisted side-channel attacks on non-prefix kv cache in rag," *arXiv preprint arXiv:2606.21842*, 2026. Consulted arXiv:2606.21842v1; archived access 18 October 2026.

[12] G. Wu, Z. li, Y. Zhang, Z. Zhang, J. Niu, Y. Wu, and Y. Zhang, "Cacheprune: Privacy-aware and fine-grained kv cache sharing for efficient llm inference," *arXiv preprint arXiv:2605.23640v1*, 2026. Consulted 2605.23640v1; source-scoped access 21 October 2026.

[13] T. A. Ghaleb, "Fingerprinting AI coding agents on GitHub," *arXiv preprint arXiv:2601.17406v1*, 2026. Consulted arXiv:2601.17406v1; archived access 18 October 2026.

[14] W. Wang, Z. Liu, H. Kou, X. Liu, and J. Shen, "The chatbot knows it's you: Dialogue attribution in unauthenticated human–LLM sessions," in *Proceedings of the ACM Web Conference 2026*, pp. 8797–8807, 2026.

[15] S. Shao, Y. Li, H. Yao, Y. Chen, Y. Yang, and Z. Qin, "Reading between the lines: Towards reliable black-box LLM fingerprinting via zeroth-order gradient estimation," 2026. Version 2, 21 January 2026.

[16] J. Leshin, M. Shah, I. Timmis, and D. Kang, "Behavioral fingerprints for LLM endpoint stability and identity," 2026. Version 1, 19 March 2026.

[17] T. Zhu, Y. Wu, W. Jin, Y. Li, and G. Huang, "StepFinder: A temporal semantic framework for failure attribution in multi-agent systems," 2026. Version 1, 2 June 2026.

[18] J. Lee, Y. Wang, R. Rajat, D. Wong, M. Li, and M. Annavaram, "Otro: Oblivious tokenization path with square-root oram," *arXiv preprint arXiv:2606.17358v1*, 2026. Consulted 2606.17358v1; source-scoped access 21 October 2026.

[19] E. Wang, Z. Shafiq, and Y. Vekaria, "Fp-agent: Fingerprinting ai browsing agents," *arXiv preprint arXiv:2605.01247*, 2026. Consulted arXiv:2605.01247v1; archived access 18 October 2026.

[20] C.-Y. Wang, X.-H. Xie, T.-Z. Wang, F.-C. Luo, and Y. Cui, "Who is behind the harness? fingerprinting llms through agentic behavior," *arXiv preprint arXiv:2609.28559v1*, 2026. Consulted 2609.28559v1; source-scoped access 21 October 2026.

[21] L. L. Gan, J. Wu, L. Ge, L. Yang, Y. Song, J. Zhang, H. Jin, W. Wang, and G. Xue, "ClawGuard: Out-of-band detection of LLM agent workflow hijacking via EM side channel," *arXiv preprint arXiv:2605.06205v1*, 2026.

[22] F. George, H. Kumar, D. Pathak, K. Ray, M. Verma, and P. Moogi, "Unsupervised cycle detection in agentic applications," *arXiv preprint arXiv:2511.10650v1*, 2025.

[23] R. Solomon, Y. Y. Levi, L. Vaknin, E. Aizikovich, *et al.*, "LumiMAS: A comprehensive framework for real-time monitoring and enhanced observability in multi-agent systems," *arXiv preprint arXiv:2508.12412v2*, 2026.

[24] D. Scheinert, A. Acker, T. Wittkopp, S. Becker, H. Yous, K. Reddy, I. Farhat, H. Hacid, and O. Kao, "Beyond microservices: Testing web-scale RCA methods on GPU-driven LLM workloads," 2026. Version 1, 2 March 2026.

[25] P. Revankar, K. Chauhan, J. Kim, S. N. Nur, V. Siu, and C.-G. Wang, "Mirage: A polarity-flipping encoding subspace in llm agents," *arXiv preprint arXiv:2606.10304v1*, 2026. Consulted 2606.10304v1; source-scoped access 21 October 2026.

[26] B. Dangol, "From privacy to workflow integrity: Communication-graph metadata in autonomous agent interoperability," *arXiv preprint arXiv:2606.07150v3*, 2026. Consulted arXiv:2606.07150v3; archived access 18 October 2026.

[27] K. Chu, Z. Lin, D. Xiang, Z. Shen, J. Su, C. Chu, Y. Yang, W. Zhang, W. Wu, and W. Zhang, "Selective KV-cache sharing to mitigate timing side-channels in LLM inference," *arXiv preprint arXiv:2508.08438v2*, 2026. Consulted arXiv:2508.08438v2; archived access 18 October 2026.

[28] G. McDonald and J. B. Or, "Whisper leak: a side-channel attack on large language models," *arXiv preprint arXiv:2511.03675*, 2025. Consulted arXiv:2511.03675v1; archived access 18 October 2026.

[29] T. Zhang, G. Saileshwar, and D. Lie, "Time will tell: Timing side channels via output token count in large language models," *arXiv preprint arXiv:2412.15431*, 2024. Consulted arXiv:2412.15431v1; archived access 18 October 2026.

[30] X. Zheng, H. Han, S. Shi, Q. Fang, Z. Du, X. Hu, and Q. Guo, "Inputsnatch: Stealing input in llm services via cache-sharing timing side-channel attacks," in *Advanced Parallel Processing Technologies (APPT 2026)*, pp. 483–497, 2027. First online August 24, 2026; publisher citation year 2027.

[31] A. Adiletta and B. Sunar, "Spill the beans: Exploiting cpu cache side-channels to leak tokens from large language models," *arXiv preprint arXiv:2505.00817*, 2025.

[32] C. Gu, R. Levine, Z. Zhang, T. Sorensen, and Y. Guo, "Behind bars: A side-channel attack on nvidia mig cache partitioning using memory barriers," in *35th USENIX Security Symposium*, pp. 5373–5392, USENIX Association, 2026.

[33] F. Chen, L. Du, J. Zhou, P. Li, and Z. Su, "Sparleak: Privacy leakage from sparse attention in llm inference on shared gpus," *arXiv preprint arXiv:2609.38830v1*, 2026. Consulted 2609.38830v1; source-scoped access 21 October 2026.

[34] Y. Jo, J. Park, E. Lee, and D. Song, "Sparseety: Extracting tokens from sparsity-exploiting llm serving systems via deterministic side channels," *arXiv preprint arXiv:2608.02995v1*, 2026. Consulted 2608.02995v1; source-scoped access 21 October 2026.

[35] R. Nazaraliyev, Y. Zhang, and N. Abu-Ghazaleh, "Page404: Breaking gpu isolation through hardware-assisted page migration," *arXiv preprint arXiv:2610.20962v1*, 2026. Consulted 2610.20962v1; source-scoped access 21 October 2026.

[36] N. Alhalawani, G. Acar, Z. Liu, and L. Batina, "Physical side-channel attacks on edge llms: Extracting output tokens and user prompts," *arXiv preprint arXiv:2610.14215v1*, 2026. Consulted 2610.14215v1; source-scoped access 21 October 2026.

[37] E. Hadad and M. Guri, "Shape and substance: Dual-layer side-channel attacks on local vision-language models," *arXiv preprint arXiv:2603.25403v1*, 2026. Consulted 2603.25403v1; source-scoped access 21 October 2026.

[38] A. Shahriar, M. N. Rahman, S. Ahmed, F. Sadeque, and M. R. Parvez, "AgentTell: Behavioural side-channel leakage in browser-use agents," *arXiv preprint arXiv:2609.32915v1*, 2026. Consulted arXiv:2609.32915v1; archived access 18 October 2026.

[39] T.-R. Chen, "Sensitive-topic leakage through llm routing metadata: Measurement and mitigation," *arXiv preprint arXiv:2610.09981v1*, 2026. Consulted 2610.09981v1; source-scoped access 21 October 2026.

[40] D. Kang, H. Jeong, J. Sheffey, P. Datta, and A. Houmansadr, "Whose agent are you? multi-layer fingerprinting and attribution of autonomous web agents," *arXiv preprint arXiv:2606.20910v1*, 2026.

[41] J.-J. Jiao, H. Yang, and R. Wen, "Llm-wfin: A fine-grained large language model (llm)-oriented website fingerprinting attack via fusing interrupt trace and network traffic," *Electronics*, vol. 14, no. 7, p. 1263, 2025. Consulted publisher version2025-03-23; source-scoped access 21 October 2026.

[42] S. Pouryousef, J. Lopez, S. R. Nowmi, M. M. Kamol, M. Hossain, M. Tran, and M. S. Rahman, "A large-scale benchmark and risk assessment of traffic analysis attacks on cloud LLM services," *arXiv preprint arXiv:2609.31877v1*, 2026. Consulted arXiv:2609.31877v1; archived access 18 October 2026.

[43] X. Wang, B. Zhao, M. Backes, F. Boenisch, and A. Dziedzic, "Agentprov: Auditing agentic llm api providers via tool-use policy probes," *arXiv preprint arXiv:2609.00052v1*, 2026. Consulted 2609.00052v1; source-scoped access 21 October 2026.

[44] S.-J. Park, M. Choi, J. Kim, and M.-S. Kang, "Cross-agent campaign attribution: Linking asynchronous attacks across llm agents," *arXiv preprint arXiv:2607.18826v1*, 2026. Consulted 2607.18826v1; source-scoped access 21 October 2026.

[45] I. Fayolle, S. Bouhenniche, S. Pélissier, P. Laperdrix, C. Maurice, and W. Rudametkin, "On the internet, nobody knows you're an llm bot: Unmasking web agents with multi-layer fingerprinting," *arXiv preprint arXiv:2606.30119v1*, 2026. Consulted 2606.30119v1; source-scoped access 21 October 2026.

[46] S. Banerjee, P. Sahu, M. Luo, A. Vahldiek-Oberwagner, N. J. Yadwadkar, and M. Tiwari, "SoK: A systems perspective on compound AI threats and countermeasures," *arXiv preprint arXiv:2411.13459v1*, 2024. Consulted arXiv:2411.13459v1; inspected 20 October 2026.

[47] J. Forough, M. Kogias, and H. Haddadi, "When agents handle secrets: A survey of confidential computing for agentic AI," *arXiv preprint arXiv:2605.03213v2*, 2026. Consulted arXiv:2605.03213v2; inspected 20 October 2026.

[48] O. Kotevska, S. Jha, A. Bellet, R. Hu, N. D. Bastian, R. F. da Silva, R. Madduri, and K. Kim, "Privacy foundations for multi-institutional scientific artificial intelligence," *arXiv preprint arXiv:2609.39787v1*, 2026. Consulted 2609.39787v1; source-scoped access 21 October 2026.

[49] X. Cai, R. Nithyanand, T. Wang, R. Johnson, and I. Goldberg, "A systematic approach to developing and evaluating website fingerprinting defenses," in *ACM CCS*, pp. 227–238, 2014.

[50] M. Juarez, M. Imani, M. Perry, C. Diaz, and M. Wright, "Toward an efficient website fingerprinting defense," in *ESORICS*, pp. 27–46, 2016.

[51] J. Gong and T. Wang, "Zero-delay lightweight defenses against website fingerprinting," in *29th USENIX Security Symposium*, pp. 717–734, USENIX Association, 2020.

[52] T. Wang and I. Goldberg, "Walkie-talkie: An efficient defense against passive website fingerprinting attacks," in *26th USENIX Security Symposium*, 2017.

[53] T. M. Cover and J. A. Thomas, *Elements of Information Theory*. Wiley-Interscience, 2 ed., 2006. Theorem 2.8.1, Data-processing inequality.

[54] T. Hornetz, H. Yavarzadeh, A. Cheu, A. Gascon, L. Gerlach, D. Moghimi, P. Schoppmann, M. Schwarz, and R. Zhang, "Tdxray: Microarchitectural side-channel analysis of intel tdx for real-world workloads," in *IEEE Symposium on Security and Privacy*, 2026.

[55] Z. Gao, J. Hu, F. Guo, Y. Zhang, Y. Han, S. Liu, H. Li, and Z. Lv, "I know what you said: Unveiling hardware cache side-channels in local large language model inference," in *34th USENIX Security Symposium*, pp. 1649–1668, 2025.

[56] S. Majidi, N. Mireshghallah, and K. Taram, "Leaky language models: Stealing architecture and inference optimizations via per-token timing," *arXiv preprint arXiv:2607.20723*, 2026. Consulted arXiv:2607.20723v1; archived access 19 October 2026.

[57] J. W. Kim, B. Min, K. Edemacu, Y. Choi, S.-H. Cho, and B. Jang, "Dpmemview: A memory interface for attribute-level transcript privacy in long-term llm agents," *arXiv preprint arXiv:2608.03130v1*, 2026. Consulted 2608.03130v1; source-scoped access 21 October 2026.

[58] Y.-M. Wang, Y.-X. Li, S.-L. Fan, Y.-H. Zheng, and T.-H. Chang, "Ask without telling: Local slms consult cloud llms without revealing task intent," *arXiv preprint arXiv:2609.32642v1*, 2026. Consulted 2609.32642v1; source-scoped access 21 October 2026.

[59] Z. Liu, S. van Hoek, P. Horváth, D. Lauret, X. Xu, and L. Batina, "Real-world edge neural network implementations leak private interactions through physical side channel," *arXiv preprint arXiv:2501.14512v1*, 2025. Consulted 2501.14512v1; source-scoped access 21 October 2026.

[60] P. G. Pennas, K. Papaioannou, M. Guarnieri, and T. D. Doudali, "Cachesolidarity: Preventing prefix caching side channels in multi-tenant llm serving systems," *arXiv preprint arXiv:2603.10726v1*, 2026. Consulted 2603.10726v1; source-scoped access 21 October 2026.

[61] C.-Y. Zhou, Q.-L. Jiang, S.-N. Wu, and X.-H. Zhou, "The vision encoder as a privacy boundary: Visual-token side channels in encoder-free vision-language models," *arXiv preprint arXiv:2606.14783v1*, 2026. Consulted 2606.14783v1; source-scoped access 21 October 2026.

[62] G. Politis and E. Pappas, "What gradients add to text leakage in split language models, counted per token and per document," *arXiv preprint arXiv:2610.04128v1*, 2026. Consulted 2610.04128v1; source-scoped access 21 October 2026.

[63] S. Li, T. Cui, M. Chen, X. Lin, Z. Gu, X. Deng, K. Xu, and Q. Li, "From length to content: Token-length side-channel attacks on llm api merged outputs," in *35th USENIX Security Symposium*, pp. 2187–2206, 2026.

[64] J. Wei, A. Abdulrazzag, T. Zhang, A. Muursepp, and G. Saileshwar, "When speculation spills secrets: Side channels via speculative decoding in llms," *arXiv preprint arXiv:2411.01076*, 2024. Consulted arXiv:2411.01076v4; archived access 18 October 2026.

[65] C. Gu, X. L. Li, R. Kuditipudi, P. Liang, and T. Hashimoto, "Auditing prompt caching in language model apis," in *International Conference on Machine Learning*, vol. 267, pp. 20477–20496, 2025.

[66] R. A. Bakar, "Characterizing contention-induced reliability collapse in kv-cache timing side channels for multi-tenant llm serving," *arXiv preprint arXiv:2609.06853v1*, 2026.

[67] N. Carlini and M. Nasr, "Remote timing attacks on efficient language model inference," *arXiv preprint arXiv:2410.17175v1*, 2024.

[68] C. Song, H. Wang, and R. Martin, "Personafingerprint: Measuring persona inference on modern websites with llm-driven browsing," *arXiv preprint arXiv:2605.15962*, 2026.

[69] R. Weiss, B. Konstantinov, E. Sheetrit, T. Simon, and Y. Mirsky, "Detokenization leaks: Reconstructing local LLM outputs from cache traces," *arXiv preprint arXiv:2609.06674v1*, 2026.

[70] J. Roh, E. Bagdasarian, H. Haddadi, and A. S. Shamsabadi, "SPILLage: Agentic oversharing on the web," *arXiv preprint arXiv:2602.13516v1*, 2026.

[71] G. Yu, Q. Wang, R. Lang, S. Su, and X. Wang, "PlanTwin: Privacy-preserving planning abstractions for cloud-assisted LLM agents," *arXiv preprint arXiv:2603.18377v2*, 2026.

[72] J. Xu, L. Fan, Z. Wang, X. Li, and H. Liu, "Selection-invariant communication compilers for privacy-aware multi-agent LLM workflows," *arXiv preprint arXiv:2609.26076v1*, 2026.

[73] Y. Qiao, D. Liu, H. Yang, W. Zhou, and S. Hu, "Agent tools orchestration leaks more: Dataset, benchmark, and mitigation," *arXiv preprint arXiv:2512.16310v4*, 2026. Version 4.

[74] J. Geng, R. He, Z. Fei, B. Yi, R. Wang, Z. Liu, X. Hu, X. Wu, and Q. Zeng, "Agent skills matter: Inferring proprietary skills from execution trajectories," *arXiv preprint arXiv:2607.25560v1*, 2026. Consulted arXiv:2607.25560v1; archived access 18 October 2026.

[75] H. Oderinwale, "Agent trajectories as programs: fingerprinting and programming coding-agent behavior," *arXiv preprint arXiv:2606.16988v1*, 2026.

[76] M. Umar, A. P. Marathe, M. D. Gupta, S. J. Ghosh, G. E. Suh, and W. Xiong, "Efficient memory side-channel protection for embedding gen-

eration in machine learning," in *IEEE International Symposium on High-Performance Computer Architecture*, 2025.

[77] L. Wu, C. Wang, T. Liu, Y. Zhao, and H. Wang, "From assistants to adversaries: Exploring the security risks of mobile llm agents," *arXiv preprint arXiv:2505.12981v1*, 2025. Version 1.

[78] M. Mudryi, M. Chaklosh, and G. M. Wójcik, "The hidden dangers of browsing ai agents," *arXiv preprint arXiv:2505.13076v1*, 2025. Version 1.

[79] A. Ukani, H. Haddadi, A. S. Shamsabadi, and P. Snyder, "Privacy practices of browser agents," *arXiv preprint arXiv:2512.07725*, 2025.

[80] S. Alhazbi, A. Hussain, G. Oligeri, and P. Papadimitratos, "LLMs have rhythm: Fingerprinting large language models using inter-token times and network traffic analysis," *IEEE Open Journal of the Communications Society*, vol. 6, pp. 5050–5071, 2025.

[81] R. Ding, T. Xu, X. Shen, A. A. Ding, and Y. Fei, "MoEcho: Exploiting side-channel attacks to compromise user privacy in mixture-of-experts LLMs," in *ACM SIGSAC Conference on Computer and Communications Security*, pp. 2159–2173, 2025.

[82] N. Nazari, F. Xiang, C. Fang, H. M. Makrani, A. Puri, K. Patwari, H. Sayadi, S. Rafatirad, C.-N. Chuah, and H. Homayoun, "LLM-FIN: Large language models fingerprinting attack on edge devices," in *International Symposium on Quality Electronic Design*, 2024.

[83] E. Debenedetti, G. Severi, N. Carlini, C. A. Choquette-Choo, M. Jagielski, M. Nasr, E. Wallace, and F. Tramèr, "Privacy side channels in machine learning systems," in *33rd USENIX Security Symposium*, USENIX Association, 2024.

[84] I. Yona, I. Shumailov, J. Hayes, and N. Carlini, "Stealing user prompts from mixture of experts," *arXiv preprint arXiv:2410.22884v1*, 2024.

[85] A. Chaudhuri, S. Shukla, S. Bhattacharya, and D. Mukhopadhyay, "Energon: Unveiling transformers from gpu power and thermal side-channels," in *IEEE/ACM International Conference on Computer-Aided Design*, 2025.

[86] R. H. Anwar, J. O. Weiss, T. Alves, S. Kundu, and M. T. Raza, "InferNet: Exploiting aggregate gpu profiles as side-channel for DNN architecture inference," *ACM Transactions on AI Security and Privacy*, 2026.

[87] H. Weng, R. Zhou, Y. Qu, X. Ji, and W. Xu, "ArchSnoop: LLM architecture snooping via electromagnetic side-channel on edge devices," in *Proceedings of the 19th ACM Conference on Security and Privacy in Wireless and Mobile Networks*, pp. 51–62, 2026.

[88] W. Cui, H. Zhang, Y. Huang, Q. Li, *et al.*, "SymDiag: Explainable diagnosis for LLM reasoning via neuro-symbolic verification," in *Proceedings of the 32nd ACM SIGKDD Conference on Knowledge Discovery and Data Mining V.2*, 2026. Consulted arXiv:2608.08786v1; archived access 18 October 2026.

[89] N. Lahjouji and A. G. Colaco, "Agents that know too much: A data-centric survey of privacy in LLM agents," *arXiv preprint arXiv:2606.26627*, 2026. Consulted arXiv:2606.26627v1; archived access 19 October 2026.